90-DAY JOURNEY

DAY 01/90

AI SECURITY & RED TEAMING

Day 1 — AI Red Teaming & Application Architecture

Level: Beginner | Study time: 3 hours | 3 parts + hands-on lab

IN THIS GUIDE

PART 1 AI Red Teaming Fundamentals

PART 2 Architecture & Attack Surface

PART 3 Threat Mapping & Defenses

PART 4 Hands-on Worksheet

OBJECTIVE

Understand AI Red Teaming, learn AI application architecture, identify attack surfaces, and practice basic threat mapping.

Educational use only — test only with authorization

PART 1

AI Red Teaming Fundamentals

1. What is AI Red Teaming?

AI Red Teaming is the process of testing AI-enabled applications from an attacker's perspective to identify security weaknesses, evaluate their impact, and recommend defenses.

An AI application may use a Large Language Model (LLM), databases, external APIs, document retrieval, or tools. Each component can introduce different security risks.

▸ **EXAMPLE**

A college builds an AI chatbot that answers questions using internal college documents. A security tester checks whether the chatbot follows untrusted instructions, exposes private documents, or allows users to access information without permission.

! KEY POINT

The objective is not simply to make the AI produce an unexpected answer. We need to identify whether the behavior creates a **real security risk**.

2. Traditional Pentesting vs AI Red Teaming

	Traditional Pentesting	AI Red Teaming
Scope	Tests websites, servers, APIs, and network services.	Tests AI-enabled applications and their integrations.
Looks for	Looks for vulnerabilities such as SQL injection, authentication weaknesses, and broken access control.	Investigates risks such as prompt injection, sensitive information disclosure, and excessive agent permissions.
Examines	Examines requests, responses, configurations, and logs.	Examines AI responses, retrieved documents, tool calls, and authorization boundaries.

i NOTE

Both approaches overlap. An AI application still needs traditional web and API security testing.

3. Important AI Security Risks

Risk	What it means
Prompt Injection	Untrusted input or document content may influence the AI to ignore its intended task or behave unexpectedly.
Sensitive Information Disclosure	Confidential information may be exposed to a person who should not have access to it.
Improper Output Handling	AI-generated output may be rendered or processed unsafely by another application component.
Excessive Agency	An AI agent may have more permissions or tools than it needs to complete its task.
Broken API Authorization	A user may be able to access a protected resource without the required permission.

! REMEMBER

These are possible risks to investigate. Their presence in a security framework does not prove that a particular application is vulnerable.

4. Why AI Red Teaming Matters

AI applications combine traditional software with probabilistic model behavior. A secure application must therefore consider both ordinary software vulnerabilities and AI-specific risks.

For example, an AI assistant may generate a response based on a private document. Even if the model behaves as expected, missing authorization in the document retrieval system could expose that information.

★ TAKEAWAY

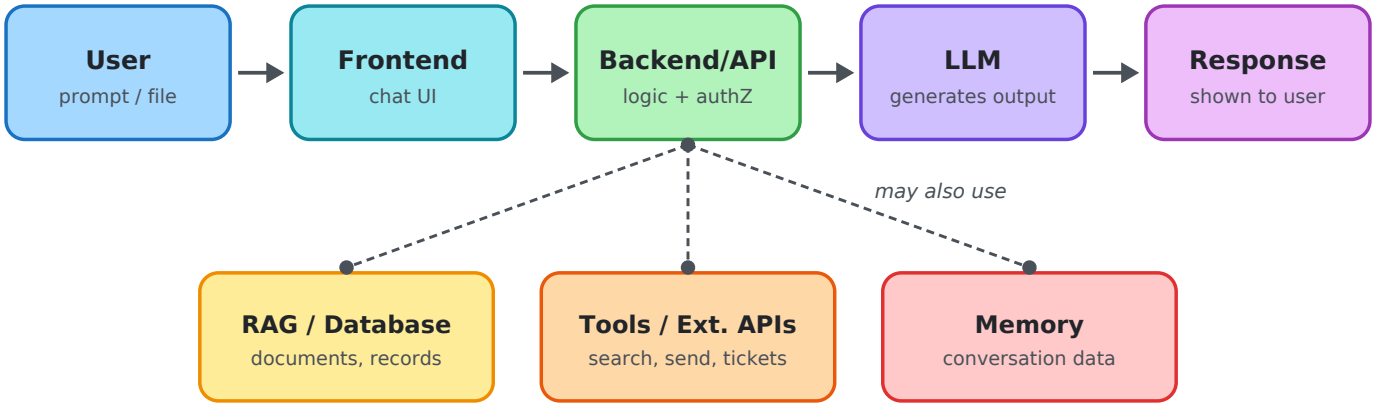
Understand what the AI application does, what information it handles, and which security failures could affect users or the organization.

PART 2

AI Application Architecture & Attack Surface

1. Basic AI Application Architecture

A typical AI application may work like this: **User → Frontend → Backend/API → LLM → Response**. Other components, such as a database, RAG system, memory, or external tools, may also be involved.



Illustrative architecture — actual apps may differ.

Component	What it does	Security question
Frontend	The interface where users enter prompts, upload files, and view responses.	Is user input handled safely? Are important security checks incorrectly performed only in the browser?
Backend / API	Receives requests, applies business logic, checks permissions, and communicates with the model or other services.	Does the server verify that the user is allowed to access each requested resource?
LLM	Processes input and generates text or other outputs.	Can untrusted input influence the model's behavior in a way that creates a security impact?
Database	Stores application data, user information, or documents.	Are protected records accessible only to authorized users and services?
RAG	Retrieves relevant documents and provides their content to the LLM to help generate an answer. *Example: a chatbot retrieves a college policy document and uses it to answer a student's question.*	Can a user retrieve documents they are not authorized to see?
Tools & External APIs	Allow an AI application to perform actions such as searching, sending messages, or creating tickets.	Are tool permissions restricted? Are sensitive actions validated and approved?
Memory	Stores or retrieves conversation-related information for later use.	Could one user's private information appear in another user's session?

2. What Is an Attack Surface?

An **attack surface** is the set of possible entry points and components through which an attacker might interact with an application. Common AI application attack surfaces include:

01 Chat input and uploaded files	**02** Backend/API endpoints
03 LLM instructions and responses	**04** RAG and document retrieval
05 Database access	**06** External tools and APIs
07 Conversation memory	**08** AI output handling

! REMEMBER

Identifying an attack surface helps us decide what to investigate. It does not automatically establish that a vulnerability exists.

3. Trust Boundaries

A **trust boundary** separates components or data with different levels of trust. Examples:

UNTRUSTED	User prompts and uploaded documents should be treated as untrusted content.
PROTECTED	Private records are protected resources.
CONTROL	Server-side authorization is a security control.
VALIDATE	External service responses should be validated where appropriate.
RESTRICT	Tool actions should be restricted by trusted permission checks.

! KEY RULE

AI-generated instructions or outputs must not replace trusted authorization controls. For example, an AI assistant saying that a user is allowed to view a document is not sufficient — the backend must independently verify the user's permission.

★ TAKEAWAY

Map the application's components, identify where untrusted input enters, and locate the resources and actions that require protection.

PART 3

Threat Mapping, Hypotheses & Defenses

1. What Is a Risk Hypothesis?

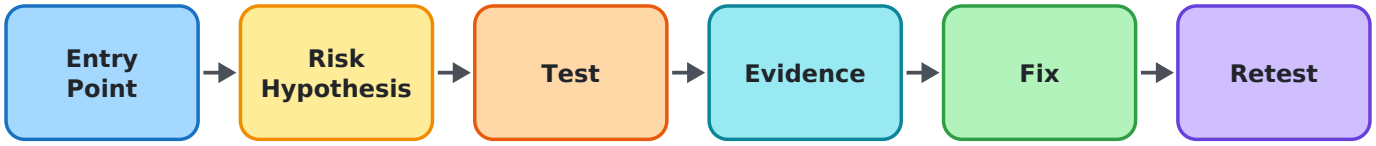
A **hypothesis** is an assumption that a potential weakness may exist. It must be tested before we can conclude whether the weakness is real.

? EXAMPLE HYPOTHESIS

"*A user without permission may be able to retrieve a confidential document through the AI chatbot.*"

This is not yet a confirmed vulnerability. It is a possibility that guides the test.

2. The Threat Mapping Process



Step	Question to ask
Entry Point	Where can the interaction begin?
Risk Hypothesis	What weakness might exist?
Test	How can we safely check the hypothesis in an authorized environment?
Evidence	What did the test actually show?
Fix	What control should be improved?
Retest	Does the same test confirm that the fix works?

3. Example Threat Mapping

Scenario: An AI chatbot retrieves documents from a knowledge base.

Step	In this scenario
Entry Point	Chat input and document retrieval.
Risk Hypothesis	A user may receive a document they are not authorized to access.
Test	Use approved test accounts with different permissions and harmless sample documents.
Evidence	Record the test account, its permissions, retrieved document identifiers, responses, and relevant logs.
Fix	Enforce document-level authorization during retrieval, before unauthorized content enters the LLM context.
Retest	Repeat the original test and verify that unauthorized documents are no longer retrieved.

4. Defense Thinking

Risk	Defense
Prompt Injection	Treat retrieved content and user input as untrusted. Use defense in depth and enforce security permissions independently of the model's instructions.
Sensitive Information Disclosure	Minimize sensitive data, restrict access, and verify authorization before providing private information.
Improper Output Handling	Validate outputs and use appropriate encoding or safe processing methods. Never directly execute untrusted model output as a privileged command.
Excessive Agency	Give agents only the permissions they need. Restrict available tools, validate arguments, and require approval for sensitive actions where appropriate.
API Authorization Weakness	Enforce server-side authorization for every protected resource. Do not rely only on frontend checks or the fact that a user is logged in.
RAG Access Control	Check document permissions during retrieval so unauthorized documents are not included in the model's context.

5. Useful Security Resources

OWASP GenAI Security Project
genai.owasp.org/

MITRE ATLAS
atlas.mitre.org/

OWASP Top 10
owasp.org/www-project-top-ten/

OWASP provides guidance on application security risks. MITRE ATLAS documents adversarial tactics and techniques relevant to AI systems.

★ TAKEAWAY
A suspected risk becomes a confirmed finding only when testing produces sufficient evidence. Every fix should be followed by a retest.

PART 4

Hands-on Practical Worksheet

LAB	TIME	ENVIRONMENT
AI Application Attack Surface Mapping	45–60 minutes	Paper-based architecture exercise or an authorized local lab

Task 1 — Draw the architecture

Draw a simple AI chatbot architecture using these components: **User · Frontend · Backend/API · LLM · RAG/database · Optional external tool**. Connect the components with arrows to show the flow of a request and response.

Draw here

Task 2 — Identify attack surfaces

Write at least five possible attack surfaces.

1. _____
2. _____
3. _____
4. _____
5. _____
6. _____

Task 3 — Write risk hypotheses

Complete at least three of these statements.

Hypothesis 1

Entry point: _____

A possible risk is: _____

Hypothesis 2

Entry point: _____

A possible risk is: _____

Hypothesis 3

Entry point: _____

A possible risk is: _____

Task 4 — Map one risk

Choose one hypothesis and complete the workflow.

My threat map

Entry point: _____

Risk hypothesis: _____

Authorized test: _____

Expected secure behavior: _____

Actual evidence: _____

Suggested fix: _____

Retest result: _____

! HONESTY RULE

If you have not run a test, write **"Not tested yet"** in the evidence and retest fields. Do not invent results.

Task 5 — Defense checklist

- ☐ Identified untrusted inputs.
- ☐ Identified protected resources.
- ☐ Considered authorization checks.
- ☐ Suggested a defense for each risk.
- ☐ Distinguished assumptions from confirmed findings.
- ☐ Recorded evidence honestly.
- ☐ Planned a retest.